CLAUDE SKILLS SECURITY

Threat Taxonomy

Claude Skills Injection —
Threat & Defense Guide

VERSION 1.0.0

DOCUMENT threat-taxonomy

RationalEyes.ai

contact@rationaleyes.ai

March 2026

Table of Contents

Taxonomy Structure

Vector Catalog (SKI-001 through SKI-012)

- SKI-001 — SKILL.md Content Poisoning
- SKI-002 — Skill Trigger Hijacking
- SKI-003 — User-Uploaded Skill Persistence
- SKI-004 — Script-Based Host Compromise
- SKI-005 — Second-Order Context Poisoning
- SKI-006 — Skill Chaining and Cross-Skill Contamination
- SKI-007 — Metadata and Frontmatter Manipulation
- SKI-008 — Supply Chain Attack on Skill Repositories
- SKI-009 — Multi-Agent Skill Propagation
- SKI-010 — Cache Poisoning via Early Skill Activation
- SKI-011 — Skill-as-Command-and-Control (C2)
- SKI-012 — The Skill Authority Paradox

Summary Risk Matrix

MITRE ATLAS Cross-Reference

OWASP Cross-Reference

Key References

> ***Scope:*** *This taxonomy catalogs attack vectors specific to the Claude Skills injection surface in Claude Code (CLI/Agent SDK) and Claude.ai environments. It is intended for security researchers, red teams, platform defenders, and AI governance practitioners.*

Taxonomy Structure

Vectors are organized by Promptware Kill Chain stage (Schneier et al., arXiv:2601.09625, February 2026). Each entry maps to MITRE ATLAS (October 2025 update, 15 tactics / 66 techniques / 46 sub-techniques) and OWASP references (LLM Top 10 2025 and the new Agentic Applications Top 10 2026).

Vector Catalog

SKI-001 — SKILL.md Content Poisoning

FIELD	VALUE
ID	SKI-001
Name	SKILL.md Content Poisoning
Kill Chain Stage	Initial Access → Execution
Description	A malicious SKILL.md body contains legitimate-appearing instructions mixed with adversarial directives. Because skill content is injected into the LLM context with system-level authority (via the Skill meta-tool framing), the model follows these instructions without the skepticism applied to user input. Attack patterns include exfiltration instructions disguised as logging best practices, behavioral modifications framed as formatting guidelines, and conditional triggers using the `when_to_use` or backtick preprocessing (`!` syntax) fields. The Skill-Inject benchmark (Schmotz et al., arXiv:2602.20156) measured up to 80% attack success across 202 injection-task pairs on frontier models; the SoK paper (arXiv:2601.17548) found adaptive attacks exceed 85% against state-of-the-art defenses.
MITRE ATLAS	AML.T0051.001 — Indirect Prompt Injection

FIELD	VALUE
OWASP LLM Top 10	LLM01 (Prompt Injection)
OWASP Agentic 2026	ASI01 — Agent Goal Hijack
Risk Rating	**CRITICAL**
Attack Complexity	Low
Detection Difficulty	High
Example Reference	`examples/attacks/env-exfil-skill/`

SKI-002 — Skill Trigger Hijacking

FIELD	VALUE
ID	SKI-002
Name	Skill Trigger Hijacking
Kill Chain Stage	Initial Access
Description	Trigger matching in Claude Skills is pure LLM reasoning against natural language `description` fields — there is no algorithmic routing or embedding-based classification. An attacker who controls a skill's description controls when it activates. Overly broad descriptions cause the skill to activate on virtually every query. Targeted descriptions can intercept sensitive operations. Anthropic's own documentation recommends "slightly pushy" descriptions — a guidance norm that adversaries exploit to pre-position payloads.
MITRE ATLAS	AML.T0043 — Craft Adversarial Data
OWASP LLM Top 10	LLM01 (Prompt Injection)

FIELD	VALUE
OWASP Agentic 2026	ASI01 — Agent Goal Hijack
Risk Rating	**HIGH**
Attack Complexity	Low
Detection Difficulty	Medium
Example Reference	`examples/attacks/broad-trigger-skill/`

SKI-003 — User-Uploaded Skill Persistence

FIELD	VALUE
ID	SKI-003
Name	User-Uploaded Skill Persistence
Kill Chain Stage	Initial Access → Persistence
Description	The `/mnt/skills/user/` directory (Claude.ai) and `~/.claude/skills/` or `.claude/skills/` (Claude Code) accept user-created skills with no automated vetting, signing, or security scanning. A malicious skill placed in these directories persists across all sessions until manually removed. In multi-user environments, a skill in `.claude/skills/` is included in version control and activates for every developer who clones the project — a wormable supply chain vector analogous to the Copilot `.vscode/settings.json` attack (CVE-2025-53773, CVSS 7.8).
MITRE ATLAS	AML.T0051.001; no current mapping for skill-specific persistence (novel)
OWASP LLM Top 10	LLM03 (Supply Chain); LLM01 (Prompt Injection)

FIELD	VALUE
OWASP Agentic 2026	ASI10 — Rogue Agents
Risk Rating	**CRITICAL**
Attack Complexity	Low
Detection Difficulty	Medium
Example Reference	`examples/attacks/persistence-skill/`

SKI-004 — Script-Based Host Compromise

FIELD	VALUE
ID	SKI-004
Name	Script-Based Host Compromise
Kill Chain Stage	Execution → Exfiltration
Description	Skills containing `scripts/` subdirectories execute arbitrary code on the host machine with the full permissions of the user who launched Claude Code. There is no sandboxing between skills and the agent. Script source code never enters the LLM context — only stdout/stderr output does — creating a steganographic execution channel. Script output of 10 lines from a 500-line payload costs only ~10 context tokens, making this vector highly efficient.
MITRE ATLAS	AML.T0024 — Exfiltration via ML Inference API
OWASP LLM Top 10	LLM06 (Excessive Agency); LLM05 (Improper Output Handling)
OWASP Agentic 2026	ASI01; ASI10
Risk Rating	**CRITICAL**

FIELD	VALUE
Attack Complexity	Medium
Detection Difficulty	High
Example Reference	`examples/attacks/env-exfil-skill/`

SKI-005 — Second-Order Context Poisoning via Script Output

FIELD	VALUE
ID	SKI-005
Name	Second-Order Context Poisoning via Script Output
Kill Chain Stage	Execution → Persistence (behavioral)
Description	Script stdout is returned to Claude as a trusted `tool_result` message. A script that appears to validate configuration can inject instructions into the LLM's reasoning context through its output. This is second-order prompt injection through dynamically generated executable content — the payload is not present statically in any file and is therefore invisible to static analysis. Detection requires runtime output scanning before context injection.
MITRE ATLAS	AML.T0051.001 — Indirect Prompt Injection (novel sub-variant)
OWASP LLM Top 10	LLM05 (Improper Output Handling); LLM01 (Prompt Injection)
OWASP Agentic 2026	ASI01 — Agent Goal Hijack
Risk Rating	**CRITICAL**
Attack Complexity	High
Detection Difficulty	Critical (highest difficulty)

FIELD	VALUE
Example Reference	`examples/attacks/context-poison-skill/`

SKI-006 — Skill Chaining and Cross-Skill Contamination

FIELD	VALUE
ID	SKI-006
Name	Skill Chaining and Cross-Skill Contamination
Kill Chain Stage	Execution → Lateral Movement
Description	Skills share the same conversation context unless `context: fork` is used. A malicious skill's output persists in the context window and influences how Claude interprets subsequent skill activations. Skills are loaded progressively, enabling a carefully designed chain to escalate from low-impact initial activation to full system compromise.
MITRE ATLAS	Novel — no current mapping; closest: AML.T0051 + T1570 (Lateral Tool Transfer)
OWASP LLM Top 10	LLM01; LLM05
OWASP Agentic 2026	ASI01; ASI10
Risk Rating	**HIGH**
Attack Complexity	High
Detection Difficulty	High
Example Reference	`examples/attacks/chain-skill/`

SKI-007 — Metadata and Frontmatter Manipulation

FIELD	VALUE
ID	SKI-007
Name	Metadata and Frontmatter Manipulation
Kill Chain Stage	Privilege Escalation
Description	YAML frontmatter fields control permissions and invocation behavior. `allowed-tools` grants tools without per-use approval when the skill is active — removing the human-in-the-loop safety check. The `hooks` field enables PreToolUse/PostToolUse scripts that execute on every tool call in every session once registered. The `model` field can specify less safety-trained model variants.
MITRE ATLAS	AML.T0043 — Craft Adversarial Data
OWASP LLM Top 10	LLM06 (Excessive Agency)
OWASP Agentic 2026	ASI01
Risk Rating	**HIGH**
Attack Complexity	Low
Detection Difficulty	Medium
Example Reference	`examples/attacks/hooks-escalation-skill/`

SKI-008 — Supply Chain Attack on Skill Repositories

FIELD	VALUE
ID	SKI-008
Name	Supply Chain Attack on Skill Repositories

FIELD	VALUE
Kill Chain Stage	Initial Access
Description	Mirrors traditional software supply chain attacks against AI skill registries (ClawHub, skills.sh). There is no skill signing, provenance verification, or mandatory security review. The ClawHavoc campaign is the documented real-world instance: 335 coordinated malicious skills (824+ confirmed malicious by February 16, 2026) exploiting CVE-2026-25253 in OpenClaw. The Smithery registry breach (October 2025) exfiltrated tokens from over 3,000 applications via path traversal.
MITRE ATLAS	AML.T0020 — Poison Training Data (adapted); T1195.002 (Supply Chain)
OWASP LLM Top 10	LLM03 (Supply Chain)
OWASP Agentic 2026	ASI10
Risk Rating	**CRITICAL**
Attack Complexity	Medium
Detection Difficulty	High
Example Reference	`examples/attacks/supply-chain-demo/`

SKI-009 — Multi-Agent Skill Propagation

FIELD	VALUE
ID	SKI-009
Name	Multi-Agent Skill Propagation
Kill Chain Stage	Lateral Movement

FIELD	VALUE
Description	In Claude Code Agent Teams mode, skills and subagents are bidirectionally connected. A compromised skill in one agent can propagate through modifying shared skill directories, producing tainted orchestrator context, and spawning subagents with injected instructions. Lee & Tiwari's "Prompt Infection" paper confirmed LLM-to-LLM infection following epidemiological self-replication patterns with over 80% success.
MITRE ATLAS	Novel — closest: AML.T0051 combined with multi-agent propagation
OWASP LLM Top 10	LLM01; LLM06
OWASP Agentic 2026	ASI10 — Rogue Agents
Risk Rating	**CRITICAL**
Attack Complexity	High
Detection Difficulty	Critical (highest difficulty)
Example Reference	`examples/attacks/propagation-skill/`

SKI-010 — Cache Poisoning via Early Skill Activation

FIELD	VALUE
ID	SKI-010
Name	Cache Poisoning via Early Skill Activation
Kill Chain Stage	Persistence
Description	Claude Code supports prompt caching where shared context prefixes are cached for efficiency. Skills loaded early in a session become part of the cached prefix. A malicious skill that activates early injects instructions that persist in the prompt cache, affecting all subsequent interactions that share that cache prefix — even if the skill is later removed from the filesystem. This is analogous to web cache poisoning attacks.

FIELD	VALUE
MITRE ATLAS	AML.T0051.001 (novel sub-variant — cache-layer persistence)
OWASP LLM Top 10	LLM01; LLM05
OWASP Agentic 2026	ASI01
Risk Rating	**HIGH**
Attack Complexity	High
Detection Difficulty	Critical (highest difficulty)
Example Reference	N/A — theoretical vector; no example implemented

SKI-011 — Skill-as-Command-and-Control (C2)

FIELD	VALUE
ID	SKI-011
Name	Skill-as-Command-and-Control (C2)
Kill Chain Stage	Command and Control
Description	A skill containing a script that periodically fetches instructions from an external endpoint transforms the agent into a remotely controllable asset. The ClawHavoc campaign's 335 skills all shared C2 IP 91.92.242[.]30, confirming this pattern at production scale. CVE-2025-6514 (CVSS 9.6, JFrog Research) in mcp-remote demonstrated a confirmed MCP-layer C2 analog.
MITRE ATLAS	AML.T0051 + AML.T0024; T1071 (Application Layer Protocol)
OWASP LLM Top 10	LLM06; LLM05

FIELD	VALUE
OWASP Agentic 2026	ASI10 — Rogue Agents
Risk Rating	**CRITICAL**
Attack Complexity	Medium
Detection Difficulty	High
Example Reference	`examples/attacks/c2-skill/` (placeholder endpoints only)

SKI-012 — The Skill Authority Paradox (Architectural)

FIELD	VALUE
ID	SKI-012
Name	The Skill Authority Paradox
Kill Chain Stage	Privilege Escalation (structural)
Description	This is the foundational architectural vulnerability that enables all other vectors. User-created skills in `~/.claude/skills/` or `.claude/skills/` receive system-prompt-level trust despite having zero security review — identical authority to Anthropic's own system prompt. This is a privilege escalation path inherent to the architecture: content that would be treated with appropriate skepticism as user input is treated as trusted system instructions simply by being formatted as a SKILL.md file. Unlike other vectors, this cannot be patched by content changes alone — it requires architectural change.
MITRE ATLAS	No direct mapping — architectural vulnerability class; closest: AML.T0043
OWASP LLM Top 10	LLM01; LLM06
OWASP Agentic 2026	ASI01; ASI10

FIELD	VALUE
Risk Rating	**CRITICAL**
Attack Complexity	Low (exploited implicitly by all other vectors)
Detection Difficulty	Critical (cannot be detected — must be mitigated architecturally)
Example Reference	See all attack examples — this vector is the enabling condition

Summary Risk Matrix

ID	VECTOR NAME	KILL CHAIN STAGE	RISK RATING	ATTACK COMPLEXITY	DETECTION DIFFICULTY
SKI-001	SKILL.md Content Poisoning	Initial Access → Execution	CRITICAL	Low	High
SKI-002	Skill Trigger Hijacking	Initial Access	HIGH	Low	Medium
SKI-003	User-Uploaded Skill Persistence	Initial Access → Persistence	CRITICAL	Low	Medium
SKI-004	Script-Based Host Compromise	Execution → Exfiltration	CRITICAL	Medium	High
SKI-005	Second-Order Context Poisoning	Execution → Persistence	CRITICAL	High	Critical
SKI-006	Skill Chaining / Cross-Skill Contamination	Execution → Lateral Movement	HIGH	High	High
SKI-007	Metadata / Frontmatter Manipulation	Privilege Escalation	HIGH	Low	Medium
SKI-008	Supply Chain Attack on Repositories	Initial Access	CRITICAL	Medium	High
SKI-009	Multi-Agent Skill Propagation	Lateral Movement	CRITICAL	High	Critical
SKI-010	Cache Poisoning via Early Activation	Persistence	HIGH	High	Critical
SKI-011	Skill-as-Command-and-Control	Command and Control	CRITICAL	Medium	High
SKI-012	Skill Authority Paradox (Architectural)	Privilege Escalation	CRITICAL	Low	Critical

Count by Risk Rating

- **CRITICAL:** 8 vectors (SKI-001, SKI-003, SKI-004, SKI-005, SKI-008, SKI-009, SKI-011, SKI-012)
- **HIGH:** 4 vectors (SKI-002, SKI-006, SKI-007, SKI-010)

Count by Detection Difficulty

- **Critical (effectively undetectable without architectural controls):** 4 vectors
- **High:** 6 vectors
- **Medium:** 2 vectors

MITRE ATLAS Cross-Reference

ATLAS TECHNIQUE	VECTORS
AML.T0051.001 — Indirect Prompt Injection	SKI-001, SKI-002, SKI-005, SKI-010
AML.T0043 — Craft Adversarial Data	SKI-002, SKI-007, SKI-012
AML.T0024 — Exfiltration via ML Inference API	SKI-004, SKI-011
AML.T0020 — Poison Training Data (adapted)	SKI-008
Novel (no current mapping)	SKI-003, SKI-006, SKI-009

OWASP Cross-Reference

LLM Top 10 2025

OWASP ID	RISK	VECTORS
LLM01	Prompt Injection	SKI-001, SKI-002, SKI-003, SKI-005, SKI-006, SKI-009, SKI-010, SKI-012
LLM03	Supply Chain	SKI-003, SKI-008
LLM05	Improper Output Handling	SKI-004, SKI-005, SKI-006, SKI-010, SKI-011
LLM06	Excessive Agency	SKI-004, SKI-007, SKI-009, SKI-011, SKI-012
LLM07	System Prompt Leakage	SKI-004, SKI-011

Agentic Applications Top 10 2026

OWASP ID	RISK	VECTORS
ASI01	Agent Goal Hijack	SKI-001, SKI-002, SKI-005, SKI-006, SKI-007, SKI-010, SKI-012

OWASP ID	RISK	VECTORS
ASI10	Rogue Agents	SKI-003, SKI-006, SKI-008, SKI-009, SKI-011, SKI-012

Key References

- Schmotz et al. “Skill-Inject.” arXiv:2602.20156, February 2026.
- Schneier et al. “The Promptware Kill Chain.” arXiv:2601.09625, February 2026.
- arXiv:2601.17548 — SoK: Prompt Injection Attacks on Agentic Coding Assistants, January 2026.
- Snyk ToxicSkills Research. February 5, 2026.
- MITRE ATLAS October 2025 Update — 14 new agentic AI techniques.
- OWASP Top 10 for Agentic Applications 2026. December 2025.
- Check Point Research. CVE-2025-59536 (CVSS 8.7), CVE-2026-21852 (CVSS 5.3). February 2026.
- Lee & Tiwari. “Prompt Infection.” arXiv:2410.07283. COLM 2025.
- Debenedetti et al. “CaMeL.” arXiv:2503.18813. Google DeepMind, March 2025.
- AI SAFE2 Framework v2.1. Cloud Security Alliance, 2025–2026.